

Essential Fraud Readiness Review

An evidence-linked view of reported readiness, material risk, control priorities and leadership decisions.

PREPARED EXCLUSIVELY FOR

Rivonia Health Logistics (Pty) Ltd

Report reference RPT-MKFRS-2026-F4047D75C0

Generated 12 August 2026

Essential package

CONFIDENTIAL · INTERNAL LEADERSHIP USE

Contents

Executive summary	3
What the result means	4
Domain overview	8
Priority findings, contradictions and scenarios	11
Priority risks	18
Leadership decisions and roadmap	22
Proof requirements	24
Methodology, limitations and next steps	25
Complete supporting detail	26
Appendix: supporting material	27
E1. Supporting control actions	27
E2. Definitions and score basis	30

Executive summary

Visibility-limited assessment

Reported readiness

36

out of 100

Reactive

The submitted assessment leaves the reported readiness position provisional because the available responses do not provide enough visibility. This report identifies where the control position could not be confirmed and the evidence needed for verification.

LEADERSHIP ATTENTION

The immediate priority is visibility: knowing what is happening before a loss reveals it.

COVERAGE 100%	CRITICAL GAPS 17	MAJOR GAPS 8
------------------	---------------------	-----------------

Assessment scope and limitations

APPLICABLE CONTROLS 68	CONTROL VISIBILITY 96%	EXCLUDED AREAS 0	UNCERTAINTY RESPONSES 3
---------------------------	---------------------------	---------------------	----------------------------

This is a provisional result. Differences in assessed scope or uncertainty may limit comparison with other assessments.

3 areas was assessed through an oversight response. Excluded areas are outside the assessed scope and are not treated as weaknesses.

Visibility and proof priorities

- Transactions or operational activities above defined risk or value thresholds require independent review or approval.** The control position could not be confirmed from the response. Evidence needed: Evidence mapped to the named risk and value populationD3-Qo2, including the complete in-scope population and operating records.
- External specialists are considered when incidents require forensic, legal, cyber or investigative expertise.** The control position could not be confirmed from the response. Evidence needed: Evidence mapped to the named risk and value populationD5-Qo6, including the complete in-scope population and operating records.
- Digital activity is monitored for misuse, unauthorised transactions, suspicious data changes or channel abuse.** The control position could not be confirmed from the response. Evidence needed: Evidence mapped to the named risk and value populationD8-Qo5, including the complete in-scope population and operating records.

Use as a directional result only; differences in scope or uncertainty may limit comparison with other assessments.

The aggregate result and its ten underlying domains

The Reactive result describes the reported self-assessment position. It does not, by itself, establish operating effectiveness.

Fraud Leadership and Governance 42 Developing	Fraud Risk Identification 26 Reactive	Operational Fraud Controls 51 Developing	Fraud Detection Capability 20 Reactive	Fraud Incident Response 40 Developing
---	---	--	--	---

Whistleblowing and Reporting Culture 74 Structured	Third-Party and Supply Chain Fraud Risk 21 Reactive	Digital and Identity Fraud Risk 32 Reactive	Fraud Culture and Awareness 40 Developing	Continuous Improvement and Fraud Risk Monitoring 24 Reactive
---	--	--	--	---

What the result means

The recorded conditions requiring first attention

CRITICAL CONTROL CONDITION · FRAUD LEADERSHIP AND GOVERNANCE

A named senior owner is accountable for fraud risk management and has authority to drive action.

Within Fraud Leadership and Governance, the specific control on whether a named senior owner is accountable for fraud risk management and has authority to drive action scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

RECORDED CONTROL CONDITION · FRAUD LEADERSHIP AND GOVERNANCE

Management owns fraud risk, while internal audit or assurance functions provide independent review where they exist.

Within Fraud Leadership and Governance, the specific control on whether management owns fraud risk, while internal audit or assurance functions provide independent review where they exist scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

RECORDED CONTROL CONDITION · CONTINUOUS IMPROVEMENT AND FRAUD RISK MONITORING

The organisation periodically reviews its fraud risks and control environment.

Within Continuous Improvement and Fraud Risk Monitoring, the specific control on whether the organisation periodically reviews its fraud risks and control environment scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

PRIORITY CONTROL CONDITION · FRAUD RISK IDENTIFICATION

The organisation has completed a structured fraud risk assessment within the past two years.

Within Fraud Risk Identification, the specific control on whether the organisation has completed a structured fraud risk assessment within the past two years scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

PRIORITY CONTROL CONDITION · FRAUD RISK IDENTIFICATION

Fraud risks have been mapped across important processes such as procurement, payments, refunds, claims, stock, supplier management or service delivery.

Within Fraud Risk Identification, the specific control on whether fraud risks have been mapped across important processes such as procurement, payments, refunds, claims, stock, supplier management or service delivery scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

PRIORITY CONTROL CONDITION • OPERATIONAL FRAUD CONTROLS

Supplier onboarding includes checks on business information, ownership, banking details or other fraud-risk indicators.

Within Operational Fraud Controls, the specific control on whether supplier onboarding includes checks on business information, ownership, banking details or other fraud-risk indicators scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

PRIORITY CONTROL CONDITION • OPERATIONAL FRAUD CONTROLS

System and data access are granted based on role requirements and reviewed periodically.

Within Operational Fraud Controls, the specific control on whether system and data access are granted based on role requirements and reviewed periodically scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

PRIORITY CONTROL CONDITION • FRAUD DETECTION CAPABILITY

The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags.

Within Fraud Detection Capability, the specific control on whether the organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

PRIORITY CONTROL CONDITION • FRAUD DETECTION CAPABILITY

Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

Within Fraud Detection Capability, the specific control on whether analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

PRIORITY CONTROL CONDITION • FRAUD INCIDENT RESPONSE

The organisation has a documented process for responding to suspected fraud incidents.

Within Fraud Incident Response, the specific control on whether the organisation has a documented process for responding to suspected fraud incidents scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

PRIORITY CONTROL CONDITION • FRAUD INCIDENT RESPONSE

Evidence linked to suspected fraud is identified, preserved and handled appropriately.

Within Fraud Incident Response, the specific control on whether evidence linked to suspected fraud is identified, preserved and handled appropriately scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

PRIORITY CONTROL CONDITION • THIRD-PARTY AND SUPPLY CHAIN FRAUD RISK

Suppliers, contractors or other third parties are subject to due diligence before being engaged.

Within Third-Party and Supply Chain Fraud Risk, the specific control on whether suppliers, contractors or other third parties are subject to due diligence before being engaged scored low enough to be flagged as a critical gap. This is a specific, addressable control weakness rather than a general judgement on the whole domain.

PRIORITY CONTROL CONDITION · THIRD-PARTY AND SUPPLY CHAIN FRAUD RISK

Supplier payment processes include checks to reduce invoice manipulation, fake vendors, bank-detail changes or vendor impersonation.

Within Third-Party and Supply Chain Fraud Risk, the specific control on whether supplier payment processes include checks to reduce invoice manipulation, fake vendors, bank-detail changes or vendor impersonation scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

PRIORITY CONTROL CONDITION · DIGITAL AND IDENTITY FRAUD RISK

The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm.

Within Digital and Identity Fraud Risk, the specific control on whether the organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

PRIORITY CONTROL CONDITION · DIGITAL AND IDENTITY FRAUD RISK

Systems or digital platforms are monitored for suspicious activity such as unusual login, access, profile, transaction or account behaviour.

Within Digital and Identity Fraud Risk, the specific control on whether systems or digital platforms are monitored for suspicious activity such as unusual login, access, profile, transaction or account behaviour scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

PRIORITY CONTROL CONDITION · DIGITAL AND IDENTITY FRAUD RISK

Access to sensitive digital systems, administrator rights and confidential data is restricted and reviewed.

Within Digital and Identity Fraud Risk, the specific control on whether access to sensitive digital systems, administrator rights and confidential data is restricted and reviewed scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

PRIORITY CONTROL CONDITION · DIGITAL AND IDENTITY FRAUD RISK

The organisation can detect or investigate identity misuse, account takeover, impersonation or unauthorised profile changes where relevant.

Within Digital and Identity Fraud Risk, the specific control on whether the organisation can detect or investigate identity misuse, account takeover, impersonation or unauthorised profile changes where relevant scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

Visibility and verification priority

MATURITY CONSTRAINT · FRAUD LEADERSHIP AND GOVERNANCE

Management owns fraud risk, while internal audit or assurance functions provide independent review where they exist.

This recorded condition limits the final maturity reading to **Developing**. The constraint remains a recorded assessment result until management supplies the defined operating proof.

MATURITY CONSTRAINT · FRAUD LEADERSHIP AND GOVERNANCE

A named senior owner is accountable for fraud risk management and has authority to drive action.

This recorded condition limits the final maturity reading to **Structured**. The constraint remains a recorded assessment result until management supplies the defined operating proof.

MATURITY CONSTRAINT · CROSS-DOMAIN

Three or more critical controls scored 0, 1 or 2.

This recorded condition limits the final maturity reading to **Developing**. The constraint remains a recorded assessment result until management supplies the defined operating proof.

MATURITY CONSTRAINT · FRAUD RISK IDENTIFICATION

Core domain D2 scored below 40.

This recorded condition limits the final maturity reading to **Developing**. The constraint remains a recorded assessment result until management supplies the defined operating proof.

MATURITY CONSTRAINT · FRAUD LEADERSHIP AND GOVERNANCE

Core domain D1 scored below 60.

This recorded condition limits the final maturity reading to **Structured**. The constraint remains a recorded assessment result until management supplies the defined operating proof.

Unknown responses are not treated as confirmed control gaps. Obtain the evidence listed in this report before relying on a readiness conclusion.

Domain overview

Foundations: ownership, awareness and reporting culture

Executive ownership, risk identification, workforce awareness and safe reporting.

Fraud Leadership and Governance

42/100

Visibility and verification priority

The available response did not provide enough visibility to confirm this control position. Obtain the evidence listed in the report before treating this area as operating or as a confirmed weakness.

Priority condition: A named senior owner is accountable for fraud risk management and has authority to drive action.

Priority condition: Management owns fraud risk, while internal audit or assurance functions provide independent review where they exist.

Fraud Risk Identification

26/100

Visibility and verification priority

The available response did not provide enough visibility to confirm this control position. Obtain the evidence listed in the report before treating this area as operating or as a confirmed weakness.

Priority condition: The organisation has completed a structured fraud risk assessment within the past two years.

Priority condition: Fraud risks have been mapped across important processes such as procurement, payments, refunds, claims, stock, supplier management or service delivery.

Fraud Culture and Awareness

40/100

Visibility and verification priority

The available response did not provide enough visibility to confirm this control position. Obtain the evidence listed in the report before treating this area as operating or as a confirmed weakness.

Whistleblowing and Reporting Culture

74/100

Visibility and verification priority

The available response did not provide enough visibility to confirm this control position. Obtain the evidence listed in the report before treating this area as operating or as a confirmed weakness.

Operational defence: controls, detection and third parties

Day-to-day prevention, detection and supplier-facing control operation.

Operational Fraud Controls

51/100

Visibility and verification priority

The available response did not provide enough visibility to confirm this control position. Obtain the evidence listed in the report before treating this area as operating or as a confirmed weakness.

Priority condition: Supplier onboarding includes checks on business information, ownership, banking details or other fraud-risk indicators.

Priority condition: System and data access are granted based on role requirements and reviewed periodically.

Fraud Detection Capability

20/100

Visibility and verification priority

The available response did not provide enough visibility to confirm this control position. Obtain the evidence listed in the report before treating this area as operating or as a confirmed weakness.

Priority condition: The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags.

Priority condition: Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

Third-Party and Supply Chain Fraud Risk

21/100

Visibility and verification priority

The available response did not provide enough visibility to confirm this control position. Obtain the evidence listed in the report before treating this area as operating or as a confirmed weakness.

Priority condition: Suppliers, contractors or other third parties are subject to due diligence before being engaged.

Priority condition: Supplier payment processes include checks to reduce invoice manipulation, fake vendors, bank-detail changes or vendor impersonation.

Response and evolution: incidents, digital risk and improvement

Incident response, digital and identity defence, and continuous control improvement.

Fraud Incident Response

40/100

Visibility and verification priority

The available response did not provide enough visibility to confirm this control position. Obtain the evidence listed in the report before treating this area as operating or as a confirmed weakness.

Priority condition: The organisation has a documented process for responding to suspected fraud incidents.

Priority condition: Evidence linked to suspected fraud is identified, preserved and handled appropriately.

Visibility and verification priority

The available response did not provide enough visibility to confirm this control position. Obtain the evidence listed in the report before treating this area as operating or as a confirmed weakness.

Priority condition: The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm.

Priority condition: Systems or digital platforms are monitored for suspicious activity such as unusual login, access, profile, transaction or account behaviour.

Priority condition: Access to sensitive digital systems, administrator rights and confidential data is restricted and reviewed.

Priority condition: The organisation can detect or investigate identity misuse, account takeover, impersonation or unauthorised profile changes where relevant.

Visibility and verification priority

The available response did not provide enough visibility to confirm this control position. Obtain the evidence listed in the report before treating this area as operating or as a confirmed weakness.

Priority condition: The organisation periodically reviews its fraud risks and control environment.

Priority findings, contradictions and scenarios

The 8 conditions selected for executive attention from 34 recorded findings. The complete register of all 34 findings is provided in the supporting register issued with this report.

MATERIAL FINDING 1

MATURITY CONSTRAINT

Fraud Leadership and Governance: Management owns fraud risk, while internal audit or assurance functions provide independent review where they exist.

DOMAIN
Fraud Leadership and Governance

DIAGNOSIS
Management-versus-assurance role separation was self-assessed as "Initial / ad hoc" (Some activity may occur informally or reactively, but it is not defined, owned or reliable; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL
The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes.

IMPLEMENTATION
Moderate difficulty · 30 days

RECORDED CONTROL CONDITION
Management owns fraud risk, while internal audit or assurance functions provide independent review where they exist. — Initial / ad hoc

WHY IT MATTERS
This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

ACCOUNTABLE EXECUTIVE
CEO / Managing Director

REMAINING LIMITATION
Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

MATERIAL FINDING 2

CONTROL FAILURE

Operational Fraud Controls: Supplier onboarding includes checks on business information, ownership, banking details or other fraud-risk indicators.

DOMAIN
Operational Fraud Controls

DIAGNOSIS
Supplier-onboarding verification was self-assessed as "Not in place" (The control, process or capability does not exist or is not recognised as required; normalised score 0/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL
Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.

IMPLEMENTATION
Moderate difficulty · 60 days

RECORDED CONTROL CONDITION
Supplier onboarding includes checks on business information, ownership, banking details or other fraud-risk indicators. — Not in place

WHY IT MATTERS
This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

ACCOUNTABLE EXECUTIVE
CFO / COO

REMAINING LIMITATION
Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

MATERIAL FINDING 3		CONTROL FAILURE
Third-Party and Supply Chain Fraud Risk: Supplier payment processes include checks to reduce invoice manipulation, fake vendors, bank-detail changes or vendor impersonation.		
DOMAIN	Third-Party and Supply Chain Fraud Risk	
DIAGNOSIS	Supplier payment and bank-detail-change verification was self-assessed as "Not in place" (The control, process or capability does not exist or is not recognised as required; normalised score 0/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.	
RECOMMENDED CONTROL	Accounts Payable quarantines every bank-detail change, retrieves a contact from the pre-change vendor master, completes and records an outbound callback, obtains second-person approval from someone outside vendor-master maintenance, blocks payment until verification, and gives the CFO a monthly report of all changes, failures and bypass attempts.	
IMPLEMENTATION	Moderate difficulty · 30 days	
RECORDED CONTROL CONDITION	Supplier payment processes include checks to reduce invoice manipulation, fake vendors, bank-detail changes or vendor impersonation. — Not in place	
WHY IT MATTERS	This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	
ACCOUNTABLE EXECUTIVE	CFO	
REMAINING LIMITATION	Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.	

MATERIAL FINDING 4		CONTROL FAILURE
Fraud Incident Response: Evidence linked to suspected fraud is identified, preserved and handled appropriately.		
DOMAIN	Fraud Incident Response	
DIAGNOSIS	Fraud evidence preservation and chain of custody was self-assessed as "Initial / ad hoc" (Some activity may occur informally or reactively, but it is not defined, owned or reliable; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.	
RECOMMENDED CONTROL	The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.	
IMPLEMENTATION	High difficulty · 60 days	
RECORDED CONTROL CONDITION	Evidence linked to suspected fraud is identified, preserved and handled appropriately. — Initial / ad hoc	
WHY IT MATTERS	This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	
ACCOUNTABLE EXECUTIVE	General Counsel / COO	
REMAINING LIMITATION	Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.	

Fraud Detection Capability: The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags.

DOMAIN
Fraud Detection Capability

DIAGNOSIS
Transaction and activity monitoring was self-assessed as "Initial / ad hoc" (Some activity may occur informally or reactively, but it is not defined, owned or reliable; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL
The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with named reviewers and SLAs; coverage against the process fraud maps is reported to the fraud forum.

IMPLEMENTATION
Moderate difficulty · 90 days

RECORDED CONTROL CONDITION
The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags. — Initial / ad hoc

WHY IT MATTERS
This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

ACCOUNTABLE EXECUTIVE
CFO / COO

REMAINING LIMITATION
Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

Digital and Identity Fraud Risk: The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm.

DOMAIN
Digital and Identity Fraud Risk

DIAGNOSIS
Identity verification at risk points was self-assessed as "Initial / ad hoc" (Some activity may occur informally or reactively, but it is not defined, owned or reliable; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL
The process owner must define the risk points requiring verification — customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting — and apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records, and confirmation of contact details through independently obtained channels; results and evidence are retained under applicable data-protection obligations, exceptions require documented approval, and sensitive profile or banking changes trigger re-verification.

IMPLEMENTATION
Moderate difficulty · 60 days

RECORDED CONTROL CONDITION
The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm. — Initial / ad hoc

WHY IT MATTERS
This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

ACCOUNTABLE EXECUTIVE
COO / CFO

REMAINING LIMITATION
Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

Fraud Risk Identification: The organisation has completed a structured fraud risk assessment within the past two years.

DOMAIN
Fraud Risk Identification

DIAGNOSIS
Structured fraud risk assessment currency was self-assessed as "Initial / ad hoc" (Some activity may occur informally or reactively, but it is not defined, owned or reliable; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL
The Head of Risk must run a documented fraud risk assessment at least every two years using a repeatable method: scope the material processes and channels, identify fraud scenarios per process with the roles able to execute them, rate likelihood and impact before and after existing controls, name a treatment owner and due date for every unacceptable residual risk, and obtain governing-body approval of the plan; assessment date, participants and method are retained.

IMPLEMENTATION
Moderate difficulty · 90 days

RECORDED CONTROL CONDITION
The organisation has completed a structured fraud risk assessment within the past two years. — Initial / ad hoc

WHY IT MATTERS
This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

ACCOUNTABLE EXECUTIVE
CEO / Managing Director

REMAINING LIMITATION
Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

Continuous Improvement and Fraud Risk Monitoring: The organisation periodically reviews its fraud risks and control environment.

DOMAIN
Continuous Improvement and Fraud Risk Monitoring

DIAGNOSIS
Periodic fraud risk and control environment review was self-assessed as "Initial / ad hoc" (Some activity may occur informally or reactively, but it is not defined, owned or reliable; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL
The Head of Risk must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.

IMPLEMENTATION
Moderate difficulty · 90 days

RECORDED CONTROL CONDITION
The organisation periodically reviews its fraud risks and control environment. — Initial / ad hoc

WHY IT MATTERS
This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

ACCOUNTABLE EXECUTIVE
CEO / Managing Director

REMAINING LIMITATION
Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

CONTRADICTION 1	
Operational and privileged-access weaknesses indicate one systemic access-governance issue	
WHAT THE ASSESSMENT SHOWS	Digital and Identity Fraud Risk — Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced; Operational Fraud Controls — Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced
WHY IT MATTERS	Excess access across ordinary and privileged environments can create an end-to-end manipulation and concealment route.
LEADERSHIP VERIFICATION	Is one complete identity, role and recertification population used across ordinary and privileged access reviews?

Scenarios and assurance tests

SCENARIO 1 · CONTROL GAP

Controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier

This is a plausible scenario derived from the organisation's self-assessment evidence. It is not an allegation that the event has occurred.

ACTOR / OPPORTUNITY

Continuous Improvement and Fraud Risk Monitoring: Initial / ad hoc — Some activity may occur informally or reactively, but it is not defined, owned or reliable.; self-assessed, not independently verified.

MECHANISM

Misuse can occur when an actor exploits the recorded control condition and controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier.

CONCEALMENT

The activity may appear routine until complete population review, independent approval or exception monitoring exposes it.

WARNING INDICATORS

- An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population.
- Review overdue, or a key control found lapsed with no remediation owner.

LONG-TERM RESPONSE

The Head of Risk must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.

ENTRY POINT

The recorded control condition is engaged through Continuous Improvement and Fraud Risk Monitoring: The organisation periodically reviews its fraud risks and control environment.

CONTROL BYPASSED

A scheduled review reassesses fraud risks, tests whether key controls still operate as designed, and reports a consolidated position with owned actions to governance.

CONSEQUENCE

Impact requires case-specific validation.; Operating impact requires case-specific validation.; Impact requires case-specific validation.; Operating impact requires case-specific validation.

CONTAINMENT

Escalate to CEO / Managing Director, preserve relevant records and apply the control's escalation threshold: Review overdue, or a key control found lapsed with no remediation owner.

Without a current structured assessment, control investment follows intuition and recent events, leaving whole exposure areas unexamined and unfunded

This is a plausible scenario derived from the organisation's self-assessment evidence. It is not an allegation that the event has occurred.

ACTOR / OPPORTUNITY

Fraud Risk Identification: Initial / ad hoc — Some activity may occur informally or reactively, but it is not defined, owned or reliable.; self-assessed, not independently verified.

MECHANISM

Misuse can occur when an actor exploits the recorded control condition and without a current structured assessment, control investment follows intuition and recent events, leaving whole exposure areas unexamined and unfunded.

CONCEALMENT

The activity may appear routine until complete population review, independent approval or exception monitoring exposes it.

WARNING INDICATORS

- An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population.
- Assessment older than 24 months, or any unacceptable residual risk without a funded owner and due date.

LONG-TERM RESPONSE

The Head of Risk must run a documented fraud risk assessment at least every two years using a repeatable method: scope the material processes and channels, identify fraud scenarios per process with the roles able to execute them, rate likelihood and impact before and after existing controls, name a treatment owner and due date for every unacceptable residual risk, and obtain governing-body approval of the plan; assessment date, participants and method are retained.

ENTRY POINT

The recorded control condition is engaged through Fraud Risk Identification: The organisation has completed a structured fraud risk assessment within the past two years.

CONTROL BYPASSED

A structured fraud risk assessment completed within the past two years covers the material processes, uses a repeatable method, rates inherent and residual risk, names owners and produces a tracked treatment plan.

CONSEQUENCE

Impact requires case-specific validation.; Operating impact requires case-specific validation.; Impact requires case-specific validation.; Operating impact requires case-specific validation.

CONTAINMENT

Escalate to CEO / Managing Director, preserve relevant records and apply the control's escalation threshold: Assessment older than 24 months, or any unacceptable residual risk without a funded owner and due date.

Organisation-level risk statements hide process-level opportunity, so a specific diversion route such as refund abuse or stock write-off manipulation is never mapped to a control owner

This is a plausible scenario derived from the organisation's self-assessment evidence. It is not an allegation that the event has occurred.

ACTOR / OPPORTUNITY

Fraud Risk Identification: Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed, not independently verified.

MECHANISM

Misuse can occur when an actor exploits the recorded control condition and organisation-level risk statements hide process-level opportunity, so a specific diversion route such as refund abuse or stock write-off manipulation is never mapped to a control owner.

CONCEALMENT

The activity may appear routine until complete population review, independent approval or exception monitoring exposes it.

WARNING INDICATORS

- An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population.
- Any material process unmapped, or a mapped residual gap with no owner.

LONG-TERM RESPONSE

The Head of Risk must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.

ENTRY POINT

The recorded control condition is engaged through Fraud Risk Identification: Fraud risks have been mapped across important processes such as procurement, payments, refunds, claims, stock, supplier management or service delivery.

CONTROL BYPASSED

Each material process — procurement, payments, refunds, claims, stock, supplier management and service delivery as applicable — has documented fraud scenarios, the roles able to execute them, and the controls relied upon.

CONSEQUENCE

Impact requires case-specific validation.; Operating impact requires case-specific validation.; Impact requires case-specific validation.; Operating impact requires case-specific validation.

CONTAINMENT

Escalate to CFO / COO, preserve relevant records and apply the control's escalation threshold: Any material process unmapped, or a mapped residual gap with no owner.

Priority risks

Priority is derived from the assessment evidence and is not an independent risk assessment. The complete risk register (31 risks) is provided in the supporting register issued with this report.

RISK 1 · D10

CRITICAL

Continuous Improvement and Fraud Risk Monitoring control effectiveness risk

Because the assessed control design or operation does not meet the exact expected standard, there is a risk that controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier. Consequence pathway: Impact requires case-specific validation; Operating impact requires case-specific validation.

CAUSE
the assessed control design or operation does not meet the exact expected standard

LIKELIHOOD
High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

CURRENT CONTROL POSITION
Continuous Improvement and Fraud Risk Monitoring: Initial / ad hoc — Some activity may occur informally or reactively, but it is not defined, owned or reliable

ACCOUNTABLE EXECUTIVE
CEO / Managing Director

RISK EVENT
controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier

IMPACT
Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

REQUIRED TREATMENT
The Head of Risk must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.

TARGET PERIOD
90 days

RISK 2 · D2		CRITICAL
Fraud Risk Identification control effectiveness risk		
Because the assessed control design or operation does not meet the exact expected standard, there is a risk that without a current structured assessment, control investment follows intuition and recent events, leaving whole exposure areas unexamined and unfunded. Consequence pathway: Impact requires case-specific validation; Operating impact requires case-specific validation.		
CAUSE	RISK EVENT	
the assessed control design or operation does not meet the exact expected standard	without a current structured assessment, control investment follows intuition and recent events, leaving whole exposure areas unexamined and unfunded	
LIKELIHOOD	IMPACT	
High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.	Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.	
CURRENT CONTROL POSITION	REQUIRED TREATMENT	
Fraud Risk Identification: Initial / ad hoc — Some activity may occur informally or reactively, but it is not defined, owned or reliable	The Head of Risk must run a documented fraud risk assessment at least every two years using a repeatable method: scope the material processes and channels, identify fraud scenarios per process with the roles able to execute them, rate likelihood and impact before and after existing controls, name a treatment owner and due date for every unacceptable residual risk, and obtain governing-body approval of the plan; assessment date, participants and method are retained.	
ACCOUNTABLE EXECUTIVE	TARGET PERIOD	
CEO / Managing Director	90 days	

RISK 3 · D4		CRITICAL
Fraud Detection Capability control effectiveness risk		
Because the assessed control design or operation does not meet the exact expected standard, there is a risk that without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded. Consequence pathway: Alert backlogs can conceal important anomalies; unreviewed exceptions can allow losses to compound.		
CAUSE	RISK EVENT	
the assessed control design or operation does not meet the exact expected standard	without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded	
LIKELIHOOD	IMPACT	
High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.	Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.	
CURRENT CONTROL POSITION	REQUIRED TREATMENT	
Fraud Detection Capability: Initial / ad hoc — Some activity may occur informally or reactively, but it is not defined, owned or reliable	The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with named reviewers and SLAs; coverage against the process fraud maps is reported to the fraud forum.	
ACCOUNTABLE EXECUTIVE	TARGET PERIOD	
CFO / COO	90 days	

Digital and Identity Fraud Risk control effectiveness risk

Because the assessed control design or operation does not meet the exact expected standard, there is a risk that an unverified or impersonated identity allows a fraudulent party to receive goods, payments, credit, benefits or system access under someone else’s name. Consequence pathway: compromised or privileged access can alter records and transactions; Digital misuse can evade prevention and monitoring.	
CAUSE the assessed control design or operation does not meet the exact expected standard	RISK EVENT an unverified or impersonated identity allows a fraudulent party to receive goods, payments, credit, benefits or system access under someone else’s name
LIKELIHOOD High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.	IMPACT Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.
CURRENT CONTROL POSITION Digital and Identity Fraud Risk: Initial / ad hoc — Some activity may occur informally or reactively, but it is not defined, owned or reliable	REQUIRED TREATMENT The process owner must define the risk points requiring verification — customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting — and apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records, and confirmation of contact details through independently obtained channels; results and evidence are retained under applicable data-protection obligations, exceptions require documented approval, and sensitive profile or banking changes trigger re-verification.
ACCOUNTABLE EXECUTIVE COO / CFO	TARGET PERIOD 60 days

Fraud evidence loses integrity or chain of custody

Because evidence identification, preservation, integrity checks and custody transfers are not consistently controlled, there is a risk that material evidence is altered, lost, contaminated or cannot be shown to be authentic. Consequence pathway: evidence, retention or legal-hold duties may be breached; investigations must be repeated or abandoned; recovery, disciplinary or legal outcomes are weakened; the organisation cannot substantiate its response.	
CAUSE evidence identification, preservation, integrity checks and custody transfers are not consistently controlled	RISK EVENT material evidence is altered, lost, contaminated or cannot be shown to be authentic
LIKELIHOOD High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.	IMPACT High — High impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.
CURRENT CONTROL POSITION Fraud Incident Response: Initial / ad hoc — Some activity may occur informally or reactively, but it is not defined, owned or reliable	REQUIRED TREATMENT The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.
ACCOUNTABLE EXECUTIVE General Counsel / COO	TARGET PERIOD 60 days

Fraud-risk accountability and escalation failure

Because management ownership and independent assurance responsibilities are not clearly separated, there is a risk that a material control is operated and certified without independent challenge. Consequence pathway: assurance conclusions cannot be relied upon for remediation decisions; control failure remains undetected and permits avoidable loss; governance reporting may provide false comfort.

CAUSE
management ownership and independent assurance responsibilities are not clearly separated

LIKELIHOOD
High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

CURRENT CONTROL POSITION
Fraud Leadership and Governance: Initial / ad hoc — Some activity may occur informally or reactively, but it is not defined, owned or reliable; Fraud Leadership and Governance: Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced

ACCOUNTABLE EXECUTIVE
CEO / Managing Director

RISK EVENT
a material control is operated and certified without independent challenge

IMPACT
High — High impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

REQUIRED TREATMENT
The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes. The CEO must issue a dated fraud-risk accountability mandate naming one executive, delegated decision rights, budget authority, quarterly reporting obligations and a 30-day escalation route for overdue control actions; the company secretary retains approvals and quarterly packs.

TARGET PERIOD
30 days

Leadership decisions and roadmap

Leadership decisions required

Every decision below carries a named accountable executive and a fixed target period; each is grounded in the material findings, risks and controls set out in this report and in the complete registers in the appendix.

NO.	DECISION REQUIRED	RECOMMENDED DECISION	ACCOUNTABLE EXECUTIVE	TARGET PERIOD	CONSEQUENCE OF DELAY
1	Approve accountable executive mandates and escalation authority for priority remediation.	Name one accountable executive per linked control and approve a 30-day escalation route.	CEO / Managing Director	30 days	Priority controls remain ownerless or blocked and the maturity reading remains constrained.
2	Choose and record remediation rather than passive acceptance for Critical and High risks.	Approve linked treatments; any temporary acceptance must name an owner, expiry and compensating control.	CEO / Managing Director	30 days	Known risk pathways remain untreated without a documented acceptance basis.
3	Approve exact question-level control designs as the minimum implementation standard.	Adopt the control-improvement register; deviations require documented oversight approval.	CEO / Managing Director	30 days	Partial or inconsistent designs fail to address the causal pathway.
4	Approve specialist capacity and resources for high-difficulty controls.	Fund the named supporting functions and require a resource-confirmed delivery plan.	General Counsel / COO	60 days	The highest-complexity gaps remain open despite nominal approval.
5	Approve prerequisite-first sequencing for dependent improvements.	Use authoritative roadmap dependency IDs and escalate threatened prerequisites.	CEO / Managing Director	30 days	Downstream controls are implemented on incomplete foundations.
6	Approve a fixed governance cadence for evidence validation and overdue escalation.	Require monthly implementation reporting and quarterly independent evidence review.	CEO / Managing Director	30 days	Actions lose momentum and self-reported claims remain unverified.

30/60/90-day roadmap

This is the report's only action roadmap. Dependencies and measures are carried directly from the material findings, risks and controls set out in this report.

PERIOD	DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
30 days	Fraud Leadership and Governance	Apply immediate escalation at "Any assurance reviewer assigned operational ownership of the control under review." and deliver the exact control design: The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes.	CEO / Managing Director	No key fraud control is both operated and independently certified by the same accountable function.
60 days	Operational Fraud Controls	Apply immediate escalation at "Any supplier activated before verification or any ownership/conflict match unresolved." and deliver the exact control design: Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.	CFO / COO	100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval.
60 days	Digital and Identity Fraud Risk	Apply immediate escalation at "Activation before verification, an unapproved exception, or a sensitive change without re-verification." and deliver the exact control design: The process owner must define the risk points requiring verification — customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting — and apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records, and confirmation of contact details through independently obtained channels; results and evidence are retained under applicable data-protection obligations, exceptions require documented approval, and sensitive profile or banking changes trigger re-verification.	COO / CFO	100% of in-scope enrolments and activations carry completed verification before activation, with all exceptions approved.
90 days	Fraud Detection Capability	Apply immediate escalation at "A material process unmonitored, or a monitoring cycle missed without escalation." and deliver the exact control design: The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with named reviewers and SLAs; coverage against the process fraud maps is reported to the fraud forum.	CFO / COO	Monitoring covers all material processes on rhythm with reconciled population totals and routed output.
90 days	Continuous Improvement and Fraud Risk Monitoring	Apply immediate escalation at "Review overdue, or a key control found lapsed with no remediation owner." and deliver the exact control design: The Head of Risk must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.	CEO / Managing Director	Every key control is evidence-tested within the review cycle, with lapses remediated by due date.
90 days	Fraud Risk Identification	Apply immediate escalation at "Assessment older than 24 months, or any unacceptable residual risk without a funded owner and due date." and deliver the exact control design: The Head of Risk must run a documented fraud risk assessment at least every two years using a repeatable method: scope the material processes and channels, identify fraud scenarios per process with the roles able to execute them, rate likelihood and impact before and after existing controls, name a treatment owner and due date for every unacceptable residual risk, and obtain governing-body approval of the plan; assessment date, participants and method are retained.	CEO / Managing Director	A fraud risk assessment less than 24 months old covers all material processes with an approved, in-date treatment plan.
30 days	Fraud Incident Response	Apply immediate escalation at "Severe incident not escalated within four hours or annual tabletop overdue." and deliver the exact control design: The incident-response lead maintains a version-controlled plan covering every reported fraud incident, names an incident commander and deputies, classifies severity at intake, convenes Legal/HR/IT/Finance roles, records decisions and containment actions, and runs an annual tabletop with tracked remediation.	COO / General Counsel	All incidents receive a severity decision within four hours and annual tabletop actions close by due date.
MK Fraud Readiness · Essential · Confidential				23 / 30

PERIOD	DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
60 days	Fraud Incident Response	Apply immediate escalation at "Any unexplained custody gap, integrity mismatch or unauthorised repository access." and deliver the exact control design: The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.	General Counsel / COO	100% of sampled material-case evidence has a complete custody trail and matching integrity check.
60 days	Third-Party and Supply Chain Fraud Risk	Apply immediate escalation at "Any engagement before due diligence or unresolved ownership, sanctions or conflict match." and deliver the exact control design: The vendor-risk owner risk-rates every proposed third party, verifies legal identity and beneficial ownership from independent sources, screens sanctions/adverse and employee conflicts, documents capability and bank ownership, and requires Compliance approval for high-risk cases before contract signature or system activation.	CFO / COO	100% of new third parties have completed risk-tiered due diligence before engagement.
30 days	Third-Party and Supply Chain Fraud Risk	Apply immediate escalation at "Any unverified change released, callback mismatch or attempt to bypass segregation." and deliver the exact control design: Accounts Payable quarantines every bank-detail change, retrieves a contact from the pre-change vendor master, completes and records an outbound callback, obtains second-person approval from someone outside vendor-master maintenance, blocks payment until verification, and gives the CFO a monthly report of all changes, failures and bypass attempts.	CFO	100% of bank-detail changes independently verified before the first payment; zero unapproved bypasses.

PROOF REQUIREMENTS

Proof requirements

The items below are the immediate proof requirements linked to the priority findings above. The complete evidence checklist is not reproduced in this report; it is provided in full in the supporting register (see the closing section of this report).

NO.	EVIDENCE ARTEFACT	WHAT IT PROVES	LIKELY OWNER	STATUS
1	Approved fraud-risk RACI	Whether Management owns fraud risk, while internal audit or assurance functions provide independent review where they exist operates to the exact expected control standard across the complete in-scope population.	Head of Risk and business control owners	Not yet requested
2	Audit-committee minutes showing independent reporting	Whether Management owns fraud risk, while internal audit or assurance functions provide independent review where they exist operates to the exact expected control standard across the complete in-scope population.	Head of Risk and business control owners	Not yet requested
3	Internal audit charter or assurance mandate	Whether Management owns fraud risk, while internal audit or assurance functions provide independent review where they exist operates to the exact expected control standard across the complete in-scope population.	Head of Risk and business control owners	Not yet requested
4	Beneficial-ownership/conflict screening	Whether Supplier onboarding includes checks on business information, ownership, banking details or other fraud-risk indicators operates to the exact expected control standard across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
5	Completed onboarding checklist	Whether Supplier onboarding includes checks on business information, ownership, banking details or other fraud-risk indicators operates to the exact expected control standard across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
6	Independent registration and bank verification	Whether Supplier onboarding includes checks on business information, ownership, banking details or other fraud-risk indicators operates to the exact expected control standard across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
7	Second-reviewer approval	Whether Supplier onboarding includes checks on business information, ownership, banking details or other fraud-risk indicators operates to the exact expected control standard across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
8	Bank-detail-change request	Whether Supplier payment processes include checks to reduce invoice manipulation, fake vendors, bank-detail changes or vendor impersonation operates to the exact expected control standard across the complete in-scope population.	Accounts Payable / Vendor Master	Not yet requested

NO.	EVIDENCE ARTEFACT	WHAT IT PROVES	LIKELY OWNER	STATUS
9	Independent approval	Whether Supplier payment processes include checks to reduce invoice manipulation, fake vendors, bank-detail changes or vendor impersonation operates to the exact expected control standard across the complete in-scope population.	Accounts Payable / Vendor Master	Not yet requested
10	Monthly CFO exception report	Whether Supplier payment processes include checks to reduce invoice manipulation, fake vendors, bank-detail changes or vendor impersonation operates to the exact expected control standard across the complete in-scope population.	Accounts Payable / Vendor Master	Not yet requested
11	Payment hold/release audit trail	Whether Supplier payment processes include checks to reduce invoice manipulation, fake vendors, bank-detail changes or vendor impersonation operates to the exact expected control standard across the complete in-scope population.	Accounts Payable / Vendor Master	Not yet requested
12	Pre-existing contact record and callback log	Whether Supplier payment processes include checks to reduce invoice manipulation, fake vendors, bank-detail changes or vendor impersonation operates to the exact expected control standard across the complete in-scope population.	Accounts Payable / Vendor Master	Not yet requested
13	Chain-of-custody forms	Whether Evidence linked to suspected fraud is identified, preserved and handled appropriately operates to the exact expected control standard across the complete in-scope population.	Investigation lead / Evidence custodian	Not yet requested
14	Evidence register	Whether Evidence linked to suspected fraud is identified, preserved and handled appropriately operates to the exact expected control standard across the complete in-scope population.	Investigation lead / Evidence custodian	Not yet requested
15	Hash or seal records	Whether Evidence linked to suspected fraud is identified, preserved and handled appropriately operates to the exact expected control standard across the complete in-scope population.	Investigation lead / Evidence custodian	Not yet requested

Required population for every item: the complete in-scope population for the stated operating period, reconciled to the source system or register. Sampling expectation: review the complete population where feasible; otherwise use a documented risk-based sample including exceptions, changes and overdue items. Every item begins with the status "Not yet requested"; status changes require a separately scoped review process outside this report. This remains a self-assessment: no document, interview, transaction sample or system evidence has been independently verified for any item.

METHODOLOGY, LIMITATIONS AND NEXT STEPS

Methodology, limitations and next steps

This report is generated from a structured self-assessment across ten fraud-risk-management domains. The score, maturity constraints and advisory model use only the recorded assessment inputs and the deterministic methodology.

Limitations. This is not a forensic investigation, external audit, compliance certification or guarantee. Responses were not independently verified. Findings, scenarios and recommendations are decision-support material; leadership should obtain the specified operating proof before treating a control as effective or a finding as resolved.

Control completeness. Every priority control should state the What, Who, Population, Frequency, Evidence retained, Independent check, Escalation trigger and recipient, SLA, Effectiveness measure and Failure response.

Source: persisted assessment record, evidence model and supporting register.

Next step. Agree the proof requirements listed in this report and supporting register, then sequence them through the leadership decisions above.

Recommended next step

Commission independent validation of the approved fraud-risk RACI. Confirm across the complete in-scope population that management owns fraud risk, while internal audit or assurance functions provide independent review where they exist. This is the immediate proof priority; the complete sequence is set out in Proof requirements above and the full checklist in the appendix.

Complete supporting detail

This report presents the highest-priority matters from a complete assessment of 68 controls. The full assessment identified 34 material findings, 31 risks, 34 control improvements, 142 evidence artefacts, 34 recommended actions and 80 functional-agenda items.

Every item not shown in this report is retained in full in the supporting register issued with it. No identified weakness has been discarded.

Appendix: supporting material

Bounded supporting material for the priority matters above. The complete authoritative registers are provided in the supporting register, not reproduced here.

E1. Supporting control actions

Further control actions beyond the priority set above, in materiality order.

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
1	Fraud Leadership and Governance	Close the material control weakness recorded for "A named senior owner is accountable for fraud risk management and has authority to drive action".	The CEO must issue a dated fraud-risk accountability mandate naming one executive, delegated decision rights, budget authority, quarterly reporting obligations and a 30-day escalation route for overdue control actions; the company secretary retains approvals and quarterly packs.	CEO / Managing Director / 30 days
2	Operational Fraud Controls	Close the material control weakness recorded for "System and data access are granted based on role requirements and reviewed periodically".	System owners export the complete active-user population quarterly; line managers compare every entitlement to the approved role matrix, record keep/remove decisions, and route exceptions to IT for closure within 10 business days; Risk samples completed reviews and overdue removals are escalated to the COO.	COO / 60 days
3	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Systems or digital platforms are monitored for suspicious activity such as unusual login, access, profile, transaction or account behaviour".	The security monitoring owner inventories material login, privilege, profile and transaction events, implements risk rules across the full in-scope event feed, assigns alerts to trained analysts, preserves dispositions and escalates high-risk account compromise immediately; monthly tuning uses confirmed true/false positives.	Chief Technology Officer / 90 days
4	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Access to sensitive digital systems, administrator rights and confidential data is restricted and reviewed".	IT Security maintains a complete privileged-account register, links each human and service account to an owner and approved justification, enforces separate named admin identities and MFA, records privileged sessions, and sends the full population quarterly to system owners and Risk for independent keep/remove certification; removals close within 24 hours for leavers and five business days otherwise.	Chief Technology Officer / 60 days
5	Fraud Detection Capability	Close the material control weakness recorded for "Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions".	The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.	CFO / Chief Technology Officer / 90 days
6	Digital and Identity Fraud Risk	Close the material control weakness recorded for "The organisation can detect or investigate identity misuse, account takeover, impersonation or unauthorised profile changes where relevant".	The security operations owner must ensure authentication events, credential and multi-factor changes, profile and banking-detail changes, device and session identifiers and transaction history are logged for all material identity-bearing systems and retained for a defined period consistent with data-protection obligations; alerting covers impossible-travel and anomalous login, credential and contact-detail change followed by transaction, and dormant-account reactivation, with an investigation runbook defining containment such as session revocation and forced credential reset.	Chief Technology Officer / 90 days
7	Fraud Risk Identification	Close the material control weakness recorded for "Fraud risks have been mapped across important processes such as procurement, payments, refunds, claims, stock, supplier management or service delivery".	The Head of Risk must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.	CFO / COO / 90 days
MK Fraud Readiness · Essential · Confidential				27 / 30

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
8	Fraud Detection Capability	Close the material control weakness recorded for "Exception reports or alerts highlighting unusual transactions or activities are generated and reviewed regularly".	The monitoring owner generates a complete daily or weekly exception queue, assigns each alert to a trained reviewer, records investigation evidence and disposition, and escalates high-risk alerts immediately and all overdue alerts weekly; Risk performs a monthly closure-quality sample.	CFO / COO / 60 days
9	Continuous Improvement and Fraud Risk Monitoring	Close the material control weakness recorded for "The organisation monitors fraud trends affecting its sector, geography, customer environment or supplier base".	The Head of Risk must assign trend monitoring across the sector, operating geographies, customer environment and supplier base using industry, insurer, law-enforcement and peer sources, compare external trends against the organisation's own incident and loss data to identify both matches and gaps, and report each cycle with an explicit implication for control priorities and the treatment plan.	Head of Risk / 90 days
10	Fraud Detection Capability	Close the material control weakness recorded for "People responsible for monitoring suspicious activity know when to escalate concerns and have authority to do so".	The Head of Risk must publish escalation criteria defining what must be escalated, to whom and within what time, grant monitoring staff explicit authority to escalate directly to the fraud-risk executive or audit-committee chair where a manager is implicated, protect escalators from retaliation, train the monitoring team annually, and review escalation timeliness against criteria each quarter.	Head of Risk / 30 days
11	Fraud Risk Identification	Close the material control weakness recorded for "The organisation monitors emerging fraud threats affecting its industry, geography or operating environment".	The Head of Risk must assign responsibility for monitoring a named source set covering industry associations, insurer and broker briefings, regional law-enforcement and regulator advisories, peer and supplier incident reports and relevant local crime patterns; each cycle threats are logged, assessed for relevance to the organisation's processes, channels and geographies, and either raised as a control review with an owner or recorded as an explicit accept decision with rationale.	Head of Risk / 60 days
12	Fraud Detection Capability	Close the material control weakness recorded for "Detection controls are updated when new fraud risks, fraud methods or operational changes emerge".	The monitoring owner must reassess the detection set whenever a new fraud method is identified internally or externally, a material process or system changes, or a confirmed incident bypassed existing detection; each change is documented with rationale, tested against historical data before deployment, version-controlled, and reported with before-and-after coverage to the fraud forum.	CFO / COO / 90 days
13	Fraud Detection Capability	Close the material control weakness recorded for "Monitoring covers both internal misuse and external fraud threats where these are relevant to the organisation".	The monitoring owner must maintain a coverage matrix showing, for each material process, the indicators addressing internal misuse — override use, permission changes, adjustments by approvers, out-of-hours access — and those addressing external threats such as supplier impersonation, customer identity misuse and channel abuse; gaps in either column are logged with an owner, and coverage is reported to the fraud forum each cycle.	CFO / Chief Technology Officer / 90 days
14	Fraud Incident Response	Close the material control weakness recorded for "Employees know where and how to report suspected fraud or misconduct".	The ethics owner must publish reporting routes in plain language across the channels the workforce actually uses — induction packs, payslip inserts, notice boards at depots and sites, intranet and supervisor briefings — covering line manager, confidential channel and conflict-free alternate route; awareness is tested periodically by short survey or spot check, and results below threshold trigger a targeted re-communication for the affected sites or teams.	Chief People Officer / COO / 30 days
15	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Employees are required to disclose and manage conflicts of interest involving suppliers or third parties".	The compliance owner must require annual and on-change declarations from every employee able to influence supplier selection, contracting, receipting or payment, covering directorships, shareholdings, family relationships and outside interests; declarations are tested against the vendor master for matching surnames, addresses, contact details and bank accounts, and every declared or detected conflict receives a documented management action such as recusal, reassignment or enhanced review, recorded in a conflict register.	CFO / General Counsel / 60 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
16	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Fraud risks are considered when using agents, brokers, distributors, intermediaries, partners or outsourced service providers where relevant".	The relationship owner must ensure every intermediary or outsourced arrangement defines in contract the fraud-control obligations, the limits of delegated authority, the right to audit and obtain records, incident-notification duties and consequences for breach; oversight includes reconciliation of transactions and collections handled on the organisation's behalf, periodic assurance over the provider's relevant controls, and review of any sub-contracting before it occurs.	COO / CFO / 90 days
17	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Employees receive training on phishing, social engineering and digital impersonation attempts".	The security awareness owner must deliver role-relevant training covering payment-instruction and bank-detail-change requests, executive impersonation, urgency and secrecy pressure, credential-harvesting pages and voice or messaging impersonation; reinforce with periodic simulations targeted at high-risk roles such as finance and procurement, measure report rate as well as click rate, provide a one-click reporting route with feedback, and require verification through an independently obtained channel for any payment or bank-detail instruction.	Chief Technology Officer / Chief People Officer / 90 days
18	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Emerging digital fraud risks relevant to the organisation's operations or sector are reviewed periodically".	The information security and digital owners must jointly run a periodic review of emerging digital fraud methods relevant to the organisation's channels, drawing on vendor and industry advisories, incident experience and peer reporting; each method is assessed against current preventive and detective controls, gaps become owned actions with due dates, and accepted risks are recorded with rationale and reported to the risk forum.	Chief Technology Officer / 90 days
19	Fraud Detection Capability	Close the material control weakness recorded for "Detection controls are periodically reviewed for effectiveness by management, risk, audit or another independent reviewer".	The audit committee must commission a periodic independent evaluation of detection effectiveness covering coverage against the process fraud maps, data completeness, sample retesting of closed alerts for closure quality, and detection of deliberately seeded test conditions where practical; findings are reported to governance with owners and due dates, and remediation is tracked to closure.	Audit Committee Chair / 90 days
20	Fraud Incident Response	Close the material control weakness recorded for "Fraud investigations follow procedures that protect confidentiality, fairness, evidence and documentation".	The investigation lead must maintain written procedures covering need-to-know confidentiality and case access restriction, the subject's right to respond at the appropriate stage, interview conduct and record standards, contemporaneous documentation with dated file notes, retention and legal-privilege handling in consultation with Legal, and use of competent or accredited investigators; case files are quality-reviewed at closure against the procedure.	General Counsel / COO / 60 days
21	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Procurement processes include safeguards against collusion, manipulation, bid rigging or favouritism".	The procurement owner must require, above defined thresholds, that evaluation criteria and weightings are fixed and recorded before submissions are opened, submissions remain sealed until a scheduled opening witnessed by at least two people, evaluation is performed by a panel with signed conflict declarations, and single-source or emergency awards require documented justification and independent approval; a periodic analysis reviews award concentration, repeated near-identical pricing and rotating winners.	CFO / COO / 60 days
22	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "High-risk suppliers or third-party relationships are periodically monitored or reviewed".	The vendor-risk owner must define a risk-based monitoring cycle in which high-risk third parties are re-screened for ownership and sanctions change, reviewed for delivery and quality performance, tested for pricing drift against benchmark or contract, and analysed for spend concentration and unusual growth; findings requiring action are logged with owners, and failure to complete a cycle triggers escalation to the CFO.	CFO / COO / 90 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
23	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Procurement or vendor-management activity is subject to oversight or periodic review".	The audit committee must commission periodic independent review of procurement and vendor management covering all vendor-master creations and amendments with approver identity, award patterns by buyer and supplier, spend outside approved contracts or thresholds, use of emergency and single-source routes, and policy exception volumes by individual; findings are reported to governance with owners and due dates and tracked to closure.	Audit Committee Chair / CFO / 90 days
24	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Employees and users know how to report suspicious digital activity or account-security concerns".	The security operations owner must publish a clearly signposted route for staff and, where relevant, external users to report suspicious messages, unexpected account changes and suspected compromise, define monitored hours and target response times, connect reports directly into the alert triage and incident-response process, provide acknowledgement and outcome feedback, and track reporting volume and response time against target.	Chief Technology Officer / 60 days

E2. Definitions and score basis

DOMAIN	COVERAGE	REPORTED SCORE
Fraud Leadership and Governance	100%	42/100
Fraud Risk Identification	100%	26/100
Operational Fraud Controls	100%	51/100
Fraud Detection Capability	100%	20/100
Fraud Incident Response	100%	40/100
Whistleblowing and Reporting Culture	100%	74/100
Third-Party and Supply Chain Fraud Risk	100%	21/100
Digital and Identity Fraud Risk	100%	32/100
Fraud Culture and Awareness	100%	40/100
Continuous Improvement and Fraud Risk Monitoring	100%	24/100

Priority (risk register) and materiality (findings) are derived from the assessment evidence and the deterministic methodology; neither is an independent risk assessment. Likelihood/impact ratings are qualitative, not statistical probabilities.